水電工程管理系統
DOC-02｜API 介面與交易契約

版本 1.0（規格草案）｜2026-11-10｜狀態：規劃完成，未實作、未測試

對應文件：DOC-01 品需求規格書；DOC-03 資料庫設計規格。

目的：統一前後端 API、授權、交易、冪等、狀態轉換、錯誤及驗收契約；本文不代表可執行 OpenAPI YAML 已完成。

1. 範圍與規格優先序

- 適用 /api/v1 的組織、工程、出勤、材料、採購、報價、財務、客戶、維修及同步 API。
- 已核准政策優先於建議預設；未核准項目必須維持可配置或阻擋正式發布。
- 所有業務資料均須驗證 organization_id 與當前授權組織；前端送來的組織 ID 不視為授權證明。
- 財務、庫存、核准、正式發布與結案操作必須記錄必要稽核事件。

2. 已確認政策與 API 驗證

政策	API 不變條件
一般採購	最終應付金額 ≥ NT$3,000 → 事前核准；含折扣、稅、運費及其他應付費用
緊急採購	單次 ≤ NT$5,000；每人每日 ≤ NT$10,000；理由必填、需授權、事後核對
成本	一般數量型材料移動加權平均；序號材料個別成本
報價稅務	建立每份報價時選擇稅務模式；發布後凍結稅務快照
復原目標	RPO ≤ 1 小時、RTO ≤ 4 小時；需實際演練驗證

3. HTTP 與通用封裝

項目	契約
路徑	/api/v1；資源複數名詞，使用 kebab-case
身分	Supabase Auth Bearer token；後端每次驗證
內容	application/json；照片使用簽名上傳流程
金額	十進位字串，例如 "3000.00"，貨幣 TWD；禁止以浮點數計帳
日期	業務日期 YYYY-MM-DD；時間 RFC 3339 含時區，伺服器以 UTC 儲存
分頁	limit + cursor；固定排序，limit 上限由實作統一決定
篩選	明確白名單欄位；禁止任意 SQL 排序與過濾
版本	PATCH /狀態轉換帶 expected_version 或 If-Match
冪等	金額、庫存、核准、發布、打卡及同步提交必須提供 Idempotency-Key
追蹤	每次回應包含 request_id

成功封裝：

{"data":{"id":"uuid","status":"created"},"meta":{"request_id":"uuid"}}

失敗封裝：

{"error":{"code":"PURCHASE_LIMIT_EXCEEDED","message":"已超過緊急採購額度","details":{},"request_id":"uuid"}}

HTTP	使用時機
400	無法解析的請求格式
401	未驗證
403	權限不足
404	不存在或為避免洩露而不揭露
409	狀態、版本、冪等鍵內容不符或並行衝突
422	欄位有效但違反業務規則
429	超過頻率限制
500	非預期錯誤，對外不得洩露內部堆疊

4. 身分、組織、成員與權限 API

方法與路徑	行為／限制
GET /me	取得本人及可使用組織
GET /organizations	取得可見組織
GET /organizations/{id}/members	列出組織成員；需授權
POST /organizations/{id}/invitations	邀請成員；邀請權限、期限及單次使用
POST /invitations/accept	驗證邀請後加入組織
PATCH /organizations/{id}/members/{memberId}	角色或狀態異動；保護最後 Owner
GET /organizations/{id}/permission-grants	列出授權；需管理權限
POST /organizations/{id}/permission-grants	建立明確允許／拒絕授權，拒絕優先
GET /organizations/{id}/audit-events	稽核查詢；限制敏感欄位

5. 工程、任務、行程與出勤 API

方法與路徑	契約／副作用
POST /projects	只需工程名稱；建立籌備中工程
GET /projects/{id}	依組織與權限讀取
PATCH /projects/{id}	版本控制；不能繞過結案規則
POST /projects/{id}/close	P0 未解決缺失阻擋正常結案
POST /projects/{id}/tasks	建立任務；主負責人可空
POST /schedules	預定行程，不代表實際出勤
POST /attendance/start	開始班次；允許跨日；防重送
POST /attendance/switch-site	同班次切換工地；不建立新班次
POST /attendance/end	結束班次；不可自動於午夜下班
POST /attendance/corrections	提出更正，保留原始事件
POST /construction-reports	文字或照片至少一項；照片須已完成私有上傳
POST /defects/{id}/inspections	複驗結果；失敗保留循環紀錄
GET /projects/{id}/daily-logs	依已驗證事件產生施工日誌

6. 材料、庫存與採購 API

方法與路徑	契約／副作用
GET /materials	材料單，依授權過濾成本欄位
GET /stock-balances	現存、預留、可用量分開

POST /stock-transfers	倉庫↔工地調撥，不認列實際耗用
POST /material-usages	正式耗用；一次扣除；禁止負庫存
POST /stock-counts/{id}/post	盤點差異過帳；需核准與稽核
POST /purchase-requests	以最終應付金額判定核准需求
POST /purchase-requests/{id}/approve	有權限、版本正確、核准後不得直接覆寫
POST /purchases/emergency	單次與當日累計在同一交易檢查並占額
POST /purchase-receipts	允許部分收貨；對應入庫流水
POST /purchase-returns	建立退貨申請；未退貨不得直接產生退款
POST /supplier-payments	建立供應商付款及分配
GET /supplier-statements	依結帳區間對帳，標記差異

7. 報價、合約、請款與收付款 API

方法與路徑	契約／副作用
POST /quotations	必須 project_id XOR repair_case_id；稅務模式必選
POST /quotations/{id}/issue	凍結版本與稅務快照；冪等
POST /quotations/{id}/accept	保留接受者、時間與證據
POST /change-orders	追加／追減草稿，不直接影響合約
POST /change-orders/{id}/accept	核准後才影響有效合約
POST /billing-documents	請款單≠法定統一發票
POST /billing-documents/{id}/issue	凍結正式請款內容
POST /payments	記錄實際收到款項，防重複入帳
POST /payments/{id}/allocations	不得超配收款或超過可清償金額
POST /customer-advances	預收款獨立帳，不直接視為已開立請款
POST /advance-applications	預收抵充不再次增加現金
POST /customer-refunds	需授權與餘額驗證
GET /projects/{id}/financial-summary	有效合約、請款、收款、預收、成本分開展示

8. 客戶、維修、保固與客訴 API

方法與路徑	契約／副作用
POST /customers	只需客戶名稱
POST /sites	建立地址；門禁秘密不得放普通備註
POST /customer-site-links	同地址可連結多客戶
POST /repairs	只需 problem_description；客戶、工地、工程皆可空
POST /repairs/{id}/assignments	派工，不等於打卡
POST /repairs/{id}/visits	多次到場，與出勤事件分離
POST /repairs/{id}/actions	記錄維修行為，材料耗用仍走共用庫存 API
POST /repairs/{id}/close	P0 安全問題未解決不得正常結案
POST /repairs/{id}/reopen	重新開記錄原因
POST /warranties	保固期限、範圍及排除項目
POST /warranties/{id}/assessments	期限內不自動等於免費；保留判定證據
POST /complaints	客訴可不關聯維修案件
POST /complaints/{id}/resolve	處理結果與稽核

9. 媒體、離線同步與稽核

方法與路徑	契約／副作用
POST /media/upload-intents	授權後取得限時私有上傳資訊

POST /media/{id}/complete	驗證檔案歸屬、類型、大小及上傳結果
GET /media/{id}/access	限時授權下載，禁止永久公開 URL
POST /sync/operations	草稿及允許的離線事件；client_operation_id 去重
GET /sync/operations/{id}	取得伺服器確認或衝突狀態
GET /audit-events	僅授權人員；敏感資料遮

正式庫存過帳、核准、收款、退款、報價發布不得在離線狀態直接宣稱成功。離線打卡只可暫存待驗證事件。

10. 交易、冪等與行處理

- 冪等唯一鍵範圍至少包含 organization_id、actor_id、operation_type、idempotency_key；同鍵不同 request_hash → 409。
- 緊急採購的每日占額以 Asia/Taipei 日期、員工及組織為單位；同一交易鎖定額度並建立採購承諾。
- 庫存調撥與耗用必須在同一交易更新流水帳及餘額；禁止負庫存，失敗全部回滾。
- 收款分配、預收抵充與退款應鎖定相關餘額，確保不可超額；只記一次實際現金流。
- 報價發布、接受、追加減接受及正式請款採不可變版本或補償紀錄，不直接改寫歷史。
- 外部上傳與資料庫交易不能天然原子化；採用 pending→verified→linked 的受控狀態與清理工作。

11. 錯誤碼字典（基準）

錯誤碼	語義
ORG_ACCESS_DENIED	無組織授權
PERMISSION_DENIED	操作權限不足
VERSION_CONFLICT	版本不一致
INVALID_STATE_TRANSITION	狀態轉換不合法
IDEMPOTENCY_KEY_REUSED	相同鍵對應不同請求內容
STOCK_INSUFFICIENT	可用庫存不足
PURCHASE_APPROVAL_REQUIRED	一般採購需要事前核准
PURCHASE_LIMIT_EXCEEDED	緊急採購單次或每日超額
QUOTE_TAX_MODE_REQUIRED	未選擇報價稅務模式
PAYMENT_OVERALLOCATED	收款分配超額
P0_DEFECT_BLOCKS_CLOSURE	安全缺失阻擋結案
WARRANTY_ASSESSMENT_REQUIRED	保固須人工判定

12. API 驗收矩陣

案例	必須驗證
API-01	未登入與跨組織均拒絕，且不洩露資料
API-02	同冪等鍵重送不重複建立收款／扣料／採購
API-03	同鍵不同內容回傳 409
API-04	採購 2,999／3,000 元核准邊界
API-05	緊急 5,000／5,001 元邊界
API-06	每日 10,000／10,001 元與並行占額
API-07	移動加權平均及零庫存入庫
API-08	調撥不計為實際耗用
API-09	報價未選稅務不得發布；已發布不可覆寫
API-10	預收抵充不重複增加收款
API-11	維修只有問題描述可建立
API-12	維修到場不自動建立出勤

API-13	保固期內排除項目不自動免費
API-14	P0 缺失阻擋結案
API-15	離線重送及版本衝突
API-16	私有照片與敏感門禁資訊存取受控

13. 待決政策、未完成工作與交付門檻

- 人工成本計價、收入認列、供應商結帳日、保固期限及稅務四捨五入仍待依組織或個別契約設定.
- API 路徑與欄位屬工程設計基準；正式實作前須生成可機器驗證的 OpenAPI 3.1 YAML，並與資料庫 DDL 核對。
- 未建立或執行 API、資料庫 Migration、RLS、整合測試或部署.
- 正式交付需通過契約測試、跨組織安全測試、並行交易測試、離線同步測試及備份復原演練。